

Security+ 3.2 · Firewall Types

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.2 — Firewall Types (8:00)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Evolução: ACL stateless; stateful (lembra a conexão); NGFW (aplicação+user+threat intel+SSL inspection); UTM (NGFW+IPS+AV anti-spam num appliance); WAF (protege o HTTP/S do site: SQLi/XSS/CSRF).

Highlights que a prova cobra

- Stateful lembra a conexão; stateless é por pacote
- NGFW = stateful + aplicação + usuário + threat intelligence
- WAF (L7) protege o web app; NGFW protege o tráfego da rede

Dicas de prova & Cenários Típicos

- 'application-aware firewall'=NGFW
- 'inspects HTTP for SQL injection'=WAF

Cenário clássico de exame: 'application-level firewall for the web server'=WAF.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.2 — Firewall Types)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **WAF:** Web Application Firewall: Dispositivo ou serviço de segurança que inspeciona o tráfego HTTP/HTTPS na camada de aplicação (Camada 7), filtrando e bloqueando ataques web comuns como SQL Injection, Cross-Site Scripting (XSS) e CSRF.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A) Firewall stateful tradicional
- B) Web Application Firewall (WAF)
- C) Switch Layer 2
- D) Hub

2. Diferença entre IDS e IPS:

- A) IDS detecta e alerta; IPS detecta e BLOQUEIA
- B) São a mesma coisa
- C) IDS é de disco; IPS é de rede
- D) IPS só grava log

3. Qual a principal diferença entre IDS e IPS?

- A)** IDS bloqueia ataques, IPS apenas detecta
- B)** IDS apenas detecta e alerta, IPS pode bloquear ativamente
- C)** IDS é físico, IPS é virtual
- D)** IDS opera em camada 2, IPS em camada 3

4. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Stateful lembra a conexão; stateless é por pacote'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'NGFW = stateful + aplicação + usuário + threat intelligence'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: NGFW = stateful + aplicação + usuário + threat intelligence...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'WAF (L7) protege o web app; NGFW protege o tráfego da rede'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: WAF (L7) protege o web app; NGFW protege o tráfego da rede...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: "application-aware firewall'=NGFW'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'application-aware firewall'=NGFW...

8. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: "inspects HTTP for SQL injection'=WAF'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'inspects HTTP for SQL injection'=WAF...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: "application-level firewall for the web server'=WAF.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'application-level firewall for the web server'=WAF....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Firewall Types): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Stateful lembra a conexão; stateless é por pacote'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Web Application Firewall (WAF).

✓ **Por que está certa:** O **Web Application Firewall (WAF)** é um dispositivo de segurança que opera na camada de aplicação (Layer 7 do modelo OSI) e é projetado para inspecionar o tráfego HTTP/HTTPS, protegendo aplicações web contra ataques como SQL injection, cross-site scripting (XSS), cross-site request forgery (CSRF), entre outros. Ele analisa o conteúdo das requisições e respostas, aplicando regras baseadas em assinaturas ou comportamento anômalo. No syllabus da CompTIA Security+ (SY0-701), o WAF é explicitamente citado como um controle de segurança de camada de aplicação para proteger servidores web. Portanto, é a resposta exata para a descrição.

✗ **Por que as outras estão erradas:**

- *Firewall stateful tradicional:* Um firewall stateful tradicional opera nas camadas de rede e transporte (Layer 3 e 4). Ele mantém uma tabela de estado das conexões e permite ou bloqueia pacotes com base em endereços IP, portas e estado da conexão. No entanto, ele não inspeciona o conteúdo da camada de aplicação (HTTP/HTTPS) e, portanto, não consegue detectar ataques como SQL injection ou XSS. Para inspecionar conteúdo HTTP/HTTPS, seria necessário um firewall de próxima geração (NGFW) com inspeção profunda de pacotes ou um WAF. Logo, o firewall stateful tradicional não atende ao requisito de operar na camada de aplicação e inspecionar conteúdo.
- *Switch Layer 2:* Um switch Layer 2 opera na camada de enlace de dados (Layer 2) e é responsável por encaminhar quadros Ethernet com base em endereços MAC. Ele não possui funcionalidades de inspeção de tráfego em nível de aplicação, muito menos de conteúdo HTTP/HTTPS. Sua função é conectar dispositivos dentro de uma mesma rede local, segmentando domínios de colisão. Não é um dispositivo de segurança de camada 7 e não pode inspecionar conteúdo. Portanto, está incorreto.
- *Hub:* Um hub é um dispositivo de camada física (Layer 1) que simplesmente repete sinais elétricos para todas as portas, sem qualquer inteligência de encaminhamento ou inspeção. Ele não opera em camadas superiores e não oferece nenhuma funcionalidade de segurança, muito menos inspeção de conteúdo HTTP/HTTPS. Hubs são obsoletos e substituídos por switches. Logo, não se aplica ao contexto de segurança de camada de aplicação.

2) A — IDS detecta e alerta; IPS detecta e BLOQUEIA.

✓ **Por que está certa:** A diferença fundamental entre IDS (Intrusion Detection System) e IPS (Intrusion Prevention System) está na ação tomada após a detecção de uma intrusão. O IDS monitora o tráfego de rede ou atividades do sistema em busca de padrões maliciosos e, ao detectar, gera alertas para que administradores possam investigar. Ele é passivo e não interfere no fluxo de dados. O IPS, por sua vez, é ativo: além de detectar, ele bloqueia ou impede a atividade maliciosa em tempo real, descartando pacotes, resetando conexões ou aplicando outras contramedidas. Essa distinção é cobrada no domínio de Arquitetura e Design de Segurança da Security+ (SY0-701), objetivo 3.2, que trata de tecnologias de segurança de rede.

✗ **Por que as outras estão erradas:**

- *São a mesma coisa:* IDS e IPS são tecnologias distintas com funções e posicionamentos diferentes na rede. O IDS é um sistema de detecção passiva, geralmente conectado a uma porta SPAN ou TAP, que analisa cópias do tráfego. O IPS é um sistema de prevenção ativa, instalado em linha (inline) com o fluxo de dados, capaz de bloquear ataques. Afirmar que são a mesma coisa ignora suas diferenças operacionais, de impacto na rede e de resposta a incidentes, além de contrariar definições consagradas em segurança da informação.
- *IDS é de disco; IPS é de rede:* Essa afirmação é incorreta porque ambos podem atuar em rede ou

em host. Existem HIDS (Host-based IDS) e HIPS (Host-based IPS), que monitoram atividades em um único dispositivo, incluindo chamadas de sistema e integridade de arquivos. Da mesma forma, NIDS (Network-based IDS) e NIPS (Network-based IPS) analisam tráfego de rede. A distinção não é entre disco e rede, mas entre detecção passiva e prevenção ativa. A alternativa confunde o escopo de monitoramento com o mecanismo de resposta.

- *IPS só grava log*: Essa descrição se aplica mais a um IDS, que tipicamente registra eventos e emite alertas. O IPS não se limita a gravar logs; sua função principal é bloquear ativamente tentativas de intrusão. Embora muitos IPS também gerem logs para auditoria, sua característica definidora é a capacidade de prevenir ataques em tempo real, tomando ações como descartar pacotes maliciosos ou encerrar sessões. Reduzir o IPS a um mero gravador de logs subestima sua função crítica de proteção ativa.

3) B — IDS apenas detecta e alerta, IPS pode bloquear ativamente.

✓ **Por que está certa:** A alternativa correta é 'IDS apenas detecta e alerta, IPS pode bloquear ativamente'. No ecossistema CompTIA Security+, o IDS (Intrusion Detection System) é um sistema passivo de monitoramento que inspeciona o tráfego de rede ou atividades de host em busca de assinaturas de ataque ou anomalias comportamentais. Ao identificar uma correspondência suspeita, ele gera um alerta (log, notificação SNMP, syslog) para a equipe de segurança, mas não interfere no fluxo de dados. Já o IPS (Intrusion Prevention System) opera de forma ativa e inline (no caminho do tráfego), podendo descartar pacotes maliciosos, redefinir conexões TCP, bloquear endereços IP ou aplicar políticas de mitigação em tempo real. A diferença fundamental está no posicionamento e na capacidade de ação: o IDS é um sensor fora da banda (SPAN/TAP), enquanto o IPS é um dispositivo em linha (inline) que aplica contramedidas automáticas. Essa distinção é crucial para o objetivo de segurança: detectar versus prevenir.

✗ **Por que as outras estão erradas:**

- *IDS bloqueia ataques, IPS apenas detecta*: Esta alternativa inverte completamente as funções. Um IDS (Intrusion Detection System) é, por definição, um sistema de detecção passiva: ele não possui mecanismos para bloquear tráfego, pois normalmente está conectado a uma porta SPAN de switch ou a um TAP de rede, recebendo apenas cópias dos pacotes. Sua função é analisar e alertar. Um IPS (Intrusion Prevention System), por outro lado, é projetado para prevenção ativa, operando inline e aplicando ações de bloqueio. Portanto, a afirmação está factualmente errada e contraria o modelo conceitual da CompTIA, que enfatiza a diferença entre detecção (IDS) e prevenção (IPS).
- *IDS é físico, IPS é virtual*: Esta alternativa confunde a natureza de implementação com a função. Tanto IDS quanto IPS podem ser implementados como appliances físicos, máquinas virtuais, software baseado em host (HIDS/HIPS) ou soluções em nuvem. A classificação correta não depende do meio físico ou virtual, mas sim da capacidade de resposta: detecção passiva (IDS) versus prevenção ativa (IPS). A CompTIA Security+ não associa IDS a hardware físico e IPS a virtualização; essa distinção é irrelevante para a definição funcional dos sistemas.
- *IDS opera em camada 2, IPS em camada 3*: Esta alternativa tenta associar os sistemas a camadas específicas do modelo OSI, o que é incorreto. IDS e IPS podem operar em múltiplas camadas, dependendo da configuração e do tipo de análise. Por exemplo, um IDS baseado em rede (NIDS) pode inspecionar cabeçalhos da camada 3 (IP) e da camada 4 (TCP/UDP), além de payloads da camada 7 (aplicação). Um IPS também pode atuar em diversas camadas, inclusive na camada 2 (quadros Ethernet) em modo bridge. A afirmação é uma simplificação enganosa e não reflete a arquitetura real desses sistemas, que são definidos por sua função (detecção vs. prevenção) e não por uma camada OSI fixa.

4) C — Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 3.2 (Firewall Types): Stateful lembra a conexão; stateless é por pacote.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: NGFW = stateful + aplicação + usuário + threat intelligence....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): NGFW = stateful + aplicação + usuário + threat intelligence.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: WAF (L7) protege o web app; NGFW protege o tráfego da rede....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): WAF (L7) protege o web app; NGFW protege o tráfego da rede.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'application-aware firewall'=NGFW....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): 'application-aware firewall'=NGFW.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'inspects HTTP for SQL injection'=WAF....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): 'inspects HTTP for SQL injection'=WAF.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'application-level firewall for the web server'=WAF.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): 'application-level firewall for the web server'=WAF..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Stateful lembra a conexão; stateless é por pacote....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Firewall Types): Stateful lembra a conexão; stateless é por pacote.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.